

CYBERSECURITY THREAT INTELLIGENCE REPORT

2024 - 2025 Threat Landscape

Cybersecurity Task - 1

Submitted By: Anant Suthar

B.Tech Cybersecurity | MIT ADT University, Pune

Batch 2024 - 2028

June 2025

Internship Simulation - Cybersecurity Analyst Intern

1. Introduction to Cybersecurity

1.1 What is Cybersecurity?

Cybersecurity, at its core, is the practice of protecting systems, networks, and data from digital attacks, unauthorized access, and damage. It covers everything from securing a personal laptop from malware to defending a bank's entire network from nation-state hackers. Think of it as the lock-and-alarm system of the digital world — except the attackers are constantly finding new ways to pick the lock.

The field includes several major domains:

- Network Security — protecting data as it travels across the internet
- Application Security — making sure software does not have exploitable bugs
- Endpoint Security — securing individual devices like laptops and phones
- Cloud Security — protecting data stored on third-party platforms like AWS or Azure
- Incident Response — detecting breaches and minimizing damage when attacks succeed

1.2 Why Does It Matter?

We are more digitally dependent than ever before. Banking, healthcare records, government services, education, even daily shopping — almost everything now runs online. That dependency creates opportunity for attackers. Here is what the numbers look like right now:

- Global cybercrime damages are projected to reach \$10.5 trillion annually by 2025 (Cybersecurity Ventures)
- A ransomware attack happens every 11 seconds somewhere in the world
- The average cost of a single data breach hit \$4.88 million in 2024 (IBM Cost of a Data Breach Report)
- Over 60% of small businesses that suffer a major cyberattack close within six months

For individuals, it means stolen identities, drained bank accounts, and compromised private data. For organizations, it can mean complete operational shutdown, regulatory fines, and permanent reputation damage. Cybersecurity is no longer just an IT concern — it is a business survival issue.

1.3 The Current Threat Landscape

What makes 2024-2025 particularly dangerous is the combination of three factors: AI-driven automation that lets attackers scale their operations massively, the explosion of connected devices creating millions of new attack surfaces, and increasingly organized criminal ecosystems where hacking tools and services are sold like legitimate software products.

Attackers no longer need to be technical experts. Anyone with a credit card and access to darknet forums can rent ransomware infrastructure, buy stolen credentials, and launch attacks

on businesses. The barrier to entry has dropped dramatically while the sophistication of tools has gone up. This report covers the five biggest threats coming out of this environment.

2. Threat Summary Overview

Threat	Impact Level	Primary Targets	Key Defense
AI-Powered Phishing	Critical	Everyone	Security Training + MFA
Ransomware-as-a-Service	Critical	Orgs & Hospitals	Backups + EDR
Cloud Misconfigurations	High	Businesses	CSPM + IAM Reviews
IoT Vulnerabilities	Medium	Consumers & Infra	Network Segmentation
Zero-Day Exploits	High	Enterprises & Govts	Patch Mgmt + Threat Intel

3. The Five Major Cyber Threats (2024-2025)

3.1 AI-Powered Phishing Attacks

What It Is

Phishing has existed since the 1990s, but in 2024 it got a serious upgrade. Attackers are now using large language models (LLMs) — the same technology behind AI chatbots — to generate phishing emails that are grammatically perfect, contextually relevant, and nearly indistinguishable from legitimate communication. They combine this with deepfake audio and video to impersonate executives on calls or in video messages.

A traditional phishing email used to be easy to spot — broken English, obvious grammar mistakes, weird sender domains. Modern AI-generated phishing emails read like they were written by a native speaker who knows you personally. In spear-phishing attacks, the AI can scrape a target's LinkedIn, Twitter, and company website to craft a message that references their real projects, team members, and recent events.

Impact Analysis

- **Individuals:** stolen login credentials, drained bank accounts, identity theft, and in business email compromise (BEC) attacks, victims are tricked into transferring large sums of money
- **Organizations:** credential theft leading to full network compromise, financial fraud reaching millions per incident, regulatory violations under GDPR and similar frameworks for failing to protect user data

Real-World Case Study

Incident	BoA BEC Deepfake Attack (2024)
What Happened	A finance employee received a video call that appeared to be from their CFO, asking them to approve an urgent wire transfer. The video and voice were deepfake-generated. The employee transferred \$25 million before the fraud was detected.
Outcome	Significant financial loss; the attack demonstrated that even video calls can no longer be trusted without secondary verification
Source	Reported in multiple cybersecurity outlets including KrebsOnSecurity and Wired, 2024

Preventive Measures

- **Multi-Factor Authentication (MFA):** Even if an attacker steals credentials through phishing, MFA blocks account access. Hardware keys (like YubiKey) are the gold standard.

- **Security Awareness Training:** Regular training that includes realistic AI-generated phishing simulations helps employees develop a healthy skepticism. The human firewall is your first line.
- **Email Authentication Protocols:** Deploying DMARC, DKIM, and SPF at the organizational level stops attackers from spoofing your company's own domain.
- **Out-of-Band Verification:** Establish a policy that any financial transfer or sensitive action requested via email or video must be confirmed through a separate, pre-established phone call to a known number.

3.2 Ransomware-as-a-Service (RaaS)

What It Is

Ransomware encrypts a victim's data and demands payment (usually in cryptocurrency) for the decryption key. Ransomware-as-a-Service takes this a step further by turning it into a franchise model. Criminal groups like LockBit, BlackCat/ALPHV, and Cl0p develop sophisticated ransomware platforms and then rent them out to "affiliates" — less technical criminals who pay a subscription or share a percentage of ransom payments in return for access to the infrastructure, tools, and even customer support.

This model is frighteningly effective. The core developers focus on improving the malware and evading detection, while affiliates handle the actual attacks. It has industrialized cybercrime. In 2024, RaaS groups added a new pressure tactic: double extortion, where they not only encrypt data but also steal it and threaten to publish sensitive information publicly unless the ransom is paid.

Impact Analysis

- **Individuals:** personal files encrypted and inaccessible, privacy violations if personal data is leaked publicly
- **Organizations:** complete operational shutdown that can last days or weeks, ransom demands ranging from thousands to tens of millions of dollars, regulatory penalties for exposed customer data, long-term reputational damage and loss of customer trust

Real-World Case Study

Incident	Change Healthcare / UnitedHealth Ransomware Attack (2024)
What Happened	ALPHV/BlackCat ransomware group hit Change Healthcare, the largest health payment processor in the US. The attack disrupted prescription processing and insurance claims across thousands of hospitals and pharmacies for weeks.
Outcome	UnitedHealth Group paid approximately \$22 million in ransom. Total estimated losses exceeded \$870 million. Patients were unable to

Source

access medications and providers could not process insurance claims.

Reuters, CISA advisories, and congressional testimony, 2024

Preventive Measures

- **Offline and Immutable Backups:** The single most important defense. Regular, tested backups stored offline or in immutable storage (where files cannot be modified or deleted) let organizations recover without paying ransom.
- **Endpoint Detection and Response (EDR):** Modern EDR tools like CrowdStrike Falcon or Microsoft Defender for Endpoint detect ransomware behavior — like mass file encryption — in real time and can isolate infected machines automatically.
- **Network Segmentation:** Dividing the network into isolated segments ensures that even if ransomware gets in, it cannot spread freely to encrypt everything. Critical systems like medical records or financial data should live in separate, tightly controlled network zones.
- **Principle of Least Privilege:** Users and systems should only have access to the data and resources they actually need. This limits how much damage ransomware can do even if an account gets compromised.

3.3 Cloud Security Misconfigurations

What It Is

Cloud platforms like AWS, Microsoft Azure, and Google Cloud are incredibly powerful — but they also come with hundreds of configuration options, and a single wrong setting can expose millions of records to the entire internet. Misconfigurations are now the number one cause of cloud-related breaches, according to Gartner.

Common mistakes include leaving S3 buckets publicly readable, granting overly broad IAM (Identity and Access Management) permissions, forgetting to enable encryption on databases, or accidentally exposing admin panels to the internet. These are not necessarily the result of incompetence — cloud environments are genuinely complex, and teams are often moving fast without proper security review processes.

Impact Analysis

- **Individuals:** personal data including health records, financial information, and social security numbers ending up exposed online, often without the victim knowing for months
- **Organizations:** massive regulatory fines (GDPR violations alone can cost up to 4% of global annual revenue), class-action lawsuits, loss of customer trust, and competitive intelligence falling into the hands of rivals or nation-state actors

Real-World Case Study

Incident	Microsoft Power Apps Misconfiguration (2021, discovered 2024)
What Happened	38 terabytes of internal Microsoft data were accidentally exposed through a misconfigured Azure Blob Storage URL shared by an employee on GitHub. The exposure included private keys, secrets, passwords, and internal Teams messages from Microsoft's AI research team.
Outcome	No malicious actor claimed to have exploited the data, but the incident highlighted how easily a well-intentioned developer action can expose sensitive organizational data at massive scale.
Source	Wiz Security Research, 2023 — widely covered in 2024 security retrospectives

Preventive Measures

- **Cloud Security Posture Management (CSPM):** Tools like Prisma Cloud, AWS Security Hub, or Microsoft Defender for Cloud continuously scan your cloud environment and flag misconfigurations before attackers find them.
- **Regular IAM Audits:** Periodically review who has access to what, remove unused accounts and permissions, and enforce the principle of least privilege. Over-permissioned accounts are a massive risk.
- **Infrastructure as Code (IaC) Security Scanning:** Use tools like Checkov or Terrascan to scan Terraform and CloudFormation templates for security issues before infrastructure gets deployed.

3.4 IoT Vulnerabilities

What It Is

The Internet of Things (IoT) refers to the billions of physical devices connected to the internet — smart TVs, security cameras, routers, medical devices, industrial sensors, smart doorbells, and even connected cars. By 2025, there are estimated to be over 75 billion IoT devices globally. The problem is that most of them are built with speed and cost in mind, not security.

IoT devices frequently ship with hardcoded default passwords ("admin/admin" is still embarrassingly common), outdated or unpatched firmware, no encryption for data in transit, and limited ability to receive security updates. Once compromised, they can be used as entry points into a home or corporate network, or recruited into botnets — massive networks of infected devices used to launch attacks.

Impact Analysis

- **Individuals:** compromised home routers or cameras used to spy on private life, baby monitors hijacked, smart locks bypassed, and devices recruited into botnets without the owner's knowledge
- **Organizations:** a single unsecured IoT device on a corporate network can serve as a pivot point for attackers to move laterally to more valuable systems; industrial IoT vulnerabilities can disrupt physical operations and even cause safety hazards

Real-World Case Study

Incident	Mirai Botnet (2016, with descendant variants active through 2024-2025)
What Happened	The Mirai malware scanned the internet for IoT devices using default credentials, infected hundreds of thousands of routers and cameras, and used them to launch the largest DDoS attack ever recorded at the time — knocking DNS provider Dyn offline and taking down Twitter, Netflix, Reddit, and GitHub.
Outcome	Mirai's source code was released publicly, spawning dozens of successor botnets (Moobot, Mantis, etc.) that are still active today and regularly attack infrastructure globally.
Source	CISA ICS-CERT alerts, Cloudflare DDoS threat reports 2024

Preventive Measures

- **Change Default Credentials Immediately:** Every IoT device should have its default password changed on first setup. This eliminates the easiest attack vector.
- **Network Segmentation (IoT VLAN):** Put IoT devices on a separate network segment isolated from your main computers. If a smart TV gets compromised, it should not be able to reach your work laptop.
- **Regular Firmware Updates:** When manufacturers release security patches, apply them promptly. Consider replacing devices that no longer receive firmware updates from the vendor.

3.5 Zero-Day Exploits

What It Is

A zero-day vulnerability is a software flaw that the vendor does not yet know about — meaning there are zero days of warning, zero days of available patches, and zero days of protection for users. These are the most dangerous category of vulnerability because there is literally nothing you can patch against.

Zero-days are discovered by security researchers, government agencies, and criminal hackers alike. In the criminal ecosystem, they are sold on darknet markets for anywhere from thousands to millions of dollars depending on how impactful the vulnerability is. Nation-state actors — like

the NSA or Chinese APT groups — stockpile zero-days for espionage and offensive cyber operations. Once weaponized, a zero-day can give an attacker silent access to a system for months or even years before anyone realizes something is wrong.

Impact Analysis

- Individuals: zero-days in browsers or phone operating systems allow attackers to silently compromise devices just by visiting a malicious website or opening a document — no click required in some cases
- Organizations: zero-days in enterprise software like VPNs, email servers, or industrial control systems can allow attackers to establish persistent access, exfiltrate data for months, and remain completely hidden until they choose to act

Real-World Case Study

Incident	MOVEit Transfer Zero-Day (2023-2024)
What Happened	The Cl0p ransomware group exploited a zero-day SQL injection vulnerability in MOVEit Transfer, a widely-used file transfer software. They used it to steal data from over 2,700 organizations before a patch was even available.
Outcome	Affected organizations included government agencies, universities, and major corporations globally. Total exposed individuals exceeded 93 million. Many organizations did not even know they used vulnerable MOVEit instances.
Source	CISA advisory AA23-187A, Emsisoft threat report 2024

Preventive Measures

- **Aggressive Patch Management:** While zero-days by definition have no patch initially, promptly applying patches the moment they become available closes the window of exposure. Have a defined patch SLA — critical patches within 24 hours of release.
- **Threat Intelligence Feeds:** Subscribe to vulnerability intelligence from sources like CISA's Known Exploited Vulnerabilities (KEV) catalog, NVD, and vendor security advisories to be aware of threats the moment they are disclosed.
- **Zero Trust Architecture:** Operate on the assumption that any part of your network could be compromised at any time. Verify everything, trust nothing by default, and continuously monitor for anomalous behavior that could indicate a hidden compromise.
- **Attack Surface Reduction:** The fewer internet-facing services you expose, the fewer zero-days can reach you. Regularly audit what is publicly accessible and take offline anything that does not need to be.

4. Conclusion & Future Scope

4.1 Why Proactive Cybersecurity is Non-Negotiable

Looking across all five threats in this report, one pattern is obvious: waiting until after an attack to think about security does not work. The average attacker moves faster than the average organization responds. WannaCry encrypted hundreds of thousands of machines in less than 24 hours. The MOVEit breach hit 2,700 organizations before a patch even existed. When you are reactive, you have already lost.

Proactive cybersecurity means assuming breach, building defense-in-depth, training users continuously, and keeping systems current. None of these are exotic concepts — they are basic practices that, when implemented consistently, would prevent the overwhelming majority of successful attacks. The hard truth is that most breaches exploit known vulnerabilities with available patches, credentials that should have been protected by MFA, and misconfigurations that a five-minute review would have caught.

4.2 The Need for Continuous Learning

Cybersecurity is uniquely demanding as a field because the threat landscape never stops evolving. Techniques that were cutting-edge defense last year might be obsolete today. AI is fundamentally changing both the attacker and defender sides of this equation — and nobody knows yet exactly where it leads.

For cybersecurity professionals, this means treating continuous learning as a professional responsibility, not optional. Following CISA advisories, tracking CVEs, practicing on platforms like TryHackMe and HackTheBox, earning certifications that stay current, and participating in the security research community are all part of staying effective in this field.

The threats will not slow down. But with the right mindset — curious, proactive, and always learning — defenders can absolutely stay ahead of them.

5. References

The following sources were used in the research and preparation of this report:

- **CISA (Cybersecurity & Infrastructure Security Agency)** — Known Exploited Vulnerabilities Catalog, ICS-CERT Advisories, AA23-187A: cisa.gov
- **IBM Security** — Cost of a Data Breach Report 2024: ibm.com/security/data-breach
- **KrebsOnSecurity** — Coverage of AI phishing, RaaS groups, and BEC attacks: krebsonsecurity.com
- **Cybersecurity Ventures** — Global Cybercrime Report, \$10.5 trillion projection: cybersecurityventures.com
- **Verizon** — 2024 Data Breach Investigations Report (DBIR): verizon.com/dbir

- **OWASP** — OWASP Top 10 Web Application Security Risks: owasp.org
- **Wiz Security Research** — Microsoft Azure misconfiguration disclosure (2023): wiz.io/blog
- **Emsisoft** — MOVEit Breach Impact Analysis, 2024 Ransomware Stats: emsisoft.com/en/blog
- **CISA Advisory AA23-187A** — MOVEit Transfer Vulnerability Alert: cisa.gov/news-events/cybersecurity-advisories
- **Reuters** — Change Healthcare ransomware coverage, 2024
- **Cloudflare** — DDoS Threat Report Q4 2024: cloudflare.com/learning/ddos
- **National Vulnerability Database (NVD)** — CVE records and CVSS scores: nvd.nist.gov